

Part A: Threat-to-Assurance Mapping - Shivam Patel

Prepare a concise mapping that ensures assurance requirements are grounded in real risk rather than generic best practices. Do not define assurance gates in this part. Your mapping must include:

- Threats identified in Module 3
- Controls addressing each threat
- Required assurance activity (e.g., review, test, validation)
- Evidence required to demonstrate control effectiveness

Part B: Secure AI SDLC & Assurance Plan

Produce a comprehensive assurance plan that includes the following four sections:

1. **Micky** Define a secure AI system lifecycle. Each phase must clearly identify security-relevant decision points. Be sure to include:
 - Design and architecture review
 - Model and tool onboarding
 - Data ingestion and change management

Mohammad Ahmed:

- Pre-deployment evaluation
 - Post-deployment monitoring
 - Change control and re-evaluation
2. **Joshua Remington** Define a set of launch-blocking assurance gates. Once defined, these gates are considered frozen. For each gate, specify:
 - Gate name and purpose
 - Threats addressed
 - Evidence required
 - Approval authority
 - Failure handling
 3. **Brian Che** - Develop an evidence model. Evidence must support both technical evaluation and executive decision-making. For each assurance gate, specify:
 - What evidence is produced
 - Where evidence is stored

- Who reviews the evidence
- How long is evidence retained

4. **Kingsley Ero** Establish governance and exception handling to define:

- Who can approve exceptions
- Under what conditions are exceptions permitted
- How exceptions are documented and reviewed
- How exception-related risk is tracked over time

Part A: Threat-to-Assurance Mapping

Threat	Controls	Assurance Activity	Evidence
T-1: Indirect Prompt Injection via Local Data	• Policy enforcement point • Cloud WAF • User permission enforcement • Output validation • Approved RAG source controls	• Validate only approved repositories are accessed • Review prompt and output validation rules	• Results showing malicious documents were detected and blocked • Output validation logs • Approved RAG source inventory
T-2: Unauthorized Arbitrary Code Execution via Shell Tool	• Tool approval and policy gateway • Logging • Human approval for high risk actions • Output validation	• Validate that LLM generated request cannot run until authorized by policy gateway • Attempt unapproved commands • Review approved and restricted command restrictions	• SIEM alerts (denied requests) • OS and audit logs • Tool gateway policy config
T-3: Lateral Movement via Shared Service Account	• Least-privilege access • Network segmentation • Credential rotation • Scoped service accounts • SIEM Monitoring	• Review service account permissions • Validate credential rotation • Validate data storage protections	• IAM role assignments • Authentication logs • Service account inventory • SIEM alerts for unusual activity
T-4: Audit Blind Spots and Data Exfiltration	• SIEM Monitoring	• Perform end to end testing	• DLP policy and results

	• DLP • Centralized logging • Approval records	from the original user request to email delivery • Attempt to transfer proprietary data through the platform • Review logs	• Blocked email attempts • SIEM alerts • Firewall rules
--	--	---	---